Category		Item Description	Public Docs to Review	PASS Criteria	FAIL Criteria	WARNING Criteria	GPT-4o (P/F/W)	4o Rationale	Gemini 2.5 flash (P/F/W)	Gemini Rationale	DeepSeek V3.1 (P/F/W)	DeepSeek Rationale
N1 — Supply-Chain & External Dependency Safety	**N1-01**	Pin approved sources/namespaces	Security/engineering whitepaper; software supply-chain policy; artifact/module release policy; "official registry/publisher verification" doc; third-party usage policy	"Approved registries/repositories" are specified; namespaces/publishers are pinned; allow/deny lists and geofences exist; unapproved sources are auto-blocked.	Approved source/namespace policy not published, or only listed as "recommended."	Approved sources exist, but pinning/geofencing/deny-lists are vague (e.g., missing exact names/scope).	F	Technical docs for supply-chain namespace pinning are not published.	F	The public docs do not confirm a namespace-pinning spec or pin rules.	F	Public docs do not confirm "official registry/namespace pinning," allow/deny lists, or other supply-chain namespace policies.
	N1-02	Signature & integrity verification	Code/artifact signing policy; key/certificate trust-root doc; policy stating "block on verification failure"; public page for signing scheme (Sigstore/cosign/X.509/keyless)	Verify all artifact hashes (SHA-256/512) and signatures; trust only the organization's trust roots; explicitly state "block immediately on verification failure."	Signature/hash verification unclear (recommended or partial only); no stated block criteria.	Signatures/hashes are mentioned, but trust roots/fail-to-block behavior are unclear.	F	Operational details for signing/integrity (e.g., cosign) are not disclosed.	F	Public materials do not specify the operational process for signing/verification.	F	Technical integrity controls such as artifact/release signing, hash verification, and trust roots are not published.
	N1-03	SBOM, provenance, and license checks	SBOM provisioning policy (cadence/format: SPDX/CycloneDX); SLSA/provenance (in-toto) references; license-compliance policy/allowlist	Deliver artifacts with SBOM + provenance; publish an allowed-license list; explicitly state "block on missing/mismatched data."	No SBOM/provenance or cannot provide on request; license policy not disclosed.	SBOM exists, but provenance/allow-list/deny-rule details are ambiguous.	F	SBOM/provenance standards and inspection policies are not published.	F	There is no concrete documentation on SBOM and license scanning.	F	No public documentation found for SBOM (format/cadence), provenance, or license-scan policies.
	N1-04	Format safety; converter sandboxing	Serialization & file-handling security guide; model conversion/inference transform pipeline security; sandbox/resource isolation & network egress block policy	Ban risky formats (e.g., Pickle) or confine them to a sandbox; transformers run with resource limits and network egress blocked.	No policy for handling risky formats; no mention of sandboxing/isolating transformers.	Bans/sandboxing are mentioned, but limits and network isolation are operationally unclear.	W	Format sandboxing principles exist, but thresholds/limits aren't disclosed.	W	A format-safety principle exists, but sandbox thresholds are under-specified.	W	Safety measures (e.g., PII filtering before training) are mentioned, but detailed file/format sandbox rules are insufficient.
	N1-05	Block dependency-confusion and typosquatting	Package naming policy; "official namespace first" rule; dependency-confusion response doc; auto-update policy	Publish the edit-distance threshold and "official namespace first" rule; explicitly state that PRs/builds are rejected on unapproved/mirror redirection.	No mention of look-alike package/mirror redirection handling.	Principles exist, but the threshold (edit distance) and PR/build rejection points are vague.	F	Dependency typosquatting-prevention rules are not published.	F	No documented rule for defending against dependency name confusion.	F	No documented rules for package naming or dependency-confusion defense.
	N1-06	Mandatory logging and audit trail	Logging/audit whitepaper; immutable/WORM storage policy; retention periods; mandatory field definition doc	For each artifact, record request/release ID, version, digest, signer, SBOM ID, provenance link, policy decision, reason code, and timestamp; keep them in immutable storage.	Required fields or immutable storage not specified; only generic logging mentioned.	Some fields exist, but key items (reason codes/provenance link/immutable retention) are missing.	W	Need for audit/logging is mentioned, but immutable schemas aren't published.	W	Audit principles exist, but field specifications are not disclosed.	W	Use/diagnostic logging is stated, but immutable audit schema (fields and immutable storage) is not disclosed.
	N1-07	Pass supply-chain checks before release	Release-gate/deployment checklist (public); rollback/block policy; change-management/release-notes policy	Require passing all N1-01~06 pre-deployment checks; explicitly state block/rollback on failure and capture reason codes.	No release gate/automated checks; behavior on failure not stated.	Checks/gates exist, but "pass all" criteria and block/rollback/reason-code handling are unclear.	F	Pre-release supply-chain gate technical details are not published.	F	No automation specification for the pre-release supply-chain gate.	F	No published spec for pre-release automated supply-chain gating / block & rollback.
N2 — Identity/Access & Secret Management (IAM/Secrets)	**N2-01**	Enforce SSO and MFA for user accounts	Trust/Security Center; enterprise login guide (SSO/SAML/OIDC); MFA/security-key policy; conditional access & session policy docs	"SSO-only login," "MFA required (phishing-resistant methods first: FIDO2/WebAuthn)," and "password-only login prohibited" are stated; security keys required for admins/developers; session lifetime, re-auth conditions, and device/network constraints are numeric.	Only "supported/recommended" wording without enforcement; password-only login allowed; session/condition policies unclear.	Only some roles are enforced; session/re-auth numbers are unstated; device/network conditions are partial.	W	SSO/MFA support is mentioned, but enforcement numbers aren't disclosed.	W	Account-security guidance exists, but detailed enforcement requirements are lacking.	W	Account/security contacts and support exist, but enterprise-grade MFA/SSO enforcement details are insufficient.
	N2-02	Least privilege, just-in-time elevation, separation of duties	RBAC/ABAC role definitions; privileged access/JIT elevation policy; two-person approval & cooldown policy	Roles/permissions are minimized by default; high-risk actions use JIT elevation with expiry; two-person approval and cooldown are given in minutes; ops/dev/sec duties are separated.	Broad standing admin rights; no JIT elevation/expiry, no two-person approval, no separation of duties.	JIT/two-person approval apply only to some actions; expiry/cool-down values are not specified.	W	Principle of least privilege exists, but JIT, etc., lack concrete figures.	W	Authorization principles are described, but elevation procedures lack detail.	W	Privacy/security principles are stated, but IAM operational figures such as JIT and two-person approval are not disclosed.
	N2-03	Store secrets only in secure vaults; short-lived secrets	Secrets/KMS/HSM policy; no key export & rotation cadence; secret TTL/scope policy; log-masking guideline	"No secrets in code/images/env vars"; store only in KMS/HSM; forbid raw key export; rotation cadence and TTL are numeric (e.g., TTL ≤ 1h, rotation 30d); dual approval/segregation and log masking stated.	No policy for secret locations/rotation/TTL; long-lived keys/tokens allowed; export permitted.	KMS is mentioned, but TTL/rotation values, role separation, and dual-control are unclear; many exceptions (e.g., env vars).	W	Secret-storage principles are public, but rotation cadence, etc., aren't.	W	Secret-management principles exist, but TTL/rotation rules are not disclosed.	F	Concrete operational rules for secrets/KMS/HSM (rotation period, TTL, no-export, etc.) are not in the docs.
	N2-04	Secret scanning and automatic revocation	SDLC/CI security policy; commit/PR/CI secret-scan docs; auto revoke/rotate procedures; retroactive repo scan cadence	Scan commits/PRs/CI; fail the build on detection; immediately revoke/rotate exposed secrets; periodically back-scan historical repos with a stated cadence.	Scanning is optional/developer-driven; no "fail build" or rotation procedures; no back-scans.	Scanning only in CI; warnings instead of build-fail; back-scan cadence unclear.	F	No public detail on secret scanning and auto-revocation procedures.	F	No publicly described procedure for automatic secret scanning/blocking.	F	No public evidence of commit/CI secret scanning, build blocking, or automatic secret revocation.
	N2-05	Isolate service accounts; non-interactive, keyless integration	Machine identity/service-account guide; OIDC workload identity & short-lived cert docs; console-login block policy	Issue per service/environment; disallow human/console logins (block + alert); default to keyless integration (OIDC/short-lived certs) with numeric TTLs.	Human logins allowed on service accounts; long-lived keys by default; shared accounts across environments.	Keyless integration is supported but not default; TTL not specified; warnings instead of blocking.	W	Service-account separation exists, but keyless specifics aren't published.	W	Service-identity principles exist, but implementation details are thin.	F	Integration policies for service accounts / OIDC / short-lived creds lack public detail.
	N2-06	Privileged-event alerts and immutable audit	Logging/monitoring whitepaper; SIEM/alerting policy; immutable (WORM) storage/retention policy; field schema	Real-time alerts for privilege changes/elevation/policy changes/break-glass accounts; include reason, approver, expiry; store in immutable logs; document thresholds and channels.	Only generic logging; no real-time alerting/required fields/immutable retention.	Alerts exist, but channels/thresholds are unstated; only some fields logged; retention is vague.	W	Privileged-event alerting is mentioned, but thresholds are unclear.	W	A privileged-alert framework is outlined, but thresholds are not documented.	W	Security/log collection and detection are mentioned, but real-time alerting and immutable storage specs are insufficient.
	N2-07	Permission-manifest gate before deploy	CI/CD permission review policy; excessive-privilege block rules; exception approval requirements; transparency doc link	Auto-validate permission manifests before release; block excessive privileges/shared/long-lived/wildcard tokens; exceptions require pre-approval with expiry; link results to transparency docs.	No pre-deployment permission checks; no blocking rules for wildcards or wide network scopes.	Gate exists, but block criteria are fuzzy/mostly manual; result linkage/disclosure unclear.	F	No public document for the pre-deploy "permissions spec auto-gate."	F	No spec for an automated pre-deployment permission gate.	F	No public material for a pre-deployment permission spec (auto-gate / blocking rules).
	N5-01	Document processing purpose and legal basis	Privacy policy/notice (incl. DPA); data-use & training policy; model/system card "data use" section	List processing purposes and legal bases per data flow (with examples); explicitly state "no purpose/legal basis → collection/processing prohibited."	Purpose/legal basis stated only at a high level ("for improvement") with no per-item mapping.	Purpose/legal basis exist, but only at the category level (no detailed flows/examples) or only for some services.	P	Public documentation on data-processing purposes/legal bases is thorough.	P	Processing purposes and user controls are documented.	P	The privacy notice documents processing purposes, legal bases, learnability, and filtering measures.
	N5-02	Enforce allowed fields per purpose	Public data dictionary/schema; data minimization policy; API/log field guide	Publish the allowed field list per purpose (e.g., QoS/settlement); block/auto-delete fields not on the list.	Only "data minimization" principle; allow-list/deny-list rules not published.	Per-purpose lists exist but are incomplete (missing key fields/unclear scope) or omit block/delete handling.	W	Principle of data minimization exists, but per-purpose field lists aren't published.	W	The data-minimization principle is described, but per-purpose allowlists are not disclosed.	W	Collected items are listed, but per-purpose allowlists and automatic block mappings are partial/insufficient.

Category		Item Description	Public Docs to Review	PASS Criteria	FAIL Criteria	WARNING Criteria	GPT-4o (P/F/W)	4o Rationale	Gemini 2.5 flash (P/F/W)	Gemini Rationale	DeepSeek V3.1 (P/F/W)	DeepSeek Rationale
N5 — Data Minimization & Purpose Limitation	**N5-03**	Limit input/context length; filter sensitive expressions	Input/context policy; PII/payment-data filter guide (regex/rules); embedding/RAG preprocessing docs	Publish max token count; specify PII removal/masking steps and patterns before embedding/context injection.	No max length stated; unclear whether sensitive-data filters exist.	Length limit exists but no numeric value; or only filter principles with no concrete rules/examples.	P	Input length, safety-filter guidance, and token caps are published.	P	Input constraints and safety guidance are included in the docs.	W	Mentions PII filtering (pre-training sensitive-data filtering), but lacks concrete API token/context limits and filter rules.
	N5-04	Automate retention, deletion, and deletion propagation	Retention matrix (by category); deletion/propagation policy; backup/cache/index/embedding/training-data handling docs	Publish numeric retention periods and deletion triggers per category; list propagation targets (backup/cache/index/embedding/training/checkpoints) and max propagation time (≤ N days).	Retention/deletion present but no propagation targets/deadlines; only some stores mentioned.	Propagation policy exists but misses targets (e.g., embeddings/checkpoints) or uses broad time windows.	W	Retention/deletion principles are explained, but propagation deadlines are vague.	W	Deletion principles are published, but propagation/embedding handling lacks detail.	W	Retention principles (e.g., upon account deletion) are stated, yet propagation deadlines/evidence for backups/embeddings/check points are vague.
	N5-05	Policy-as-code automatic checks and blocking	SDLC/deployment gate policy; policy-as-code/verification pipeline (public); violation block & reason-code policy	State that purpose/fields/retention/filters are auto-validated; on violation, block release and record a reason code.	Only manual review; no automatic validation/blocking or reason codes.	Some automatic validation exists, but scope is limited (only some rules) and reason-code logging not mentioned.	F	No publicly described implementation of policy-as-code auto checks/blocks.	F	Policy-as-code implementation and standard reason codes are not publicly described.	F	No public implementation for policy-as-code (automatic checks/blocks and reason codes).
	N5-06	Immutable audit log of decisions/actions	Logging/audit whitepaper; WORM/immutable storage overview; field-schema examples	Keep core fields (corr_id, purpose, fields_added/removed, filter_rule_id, retention_ttl, delete_propagation_status, reason_code, ...) and store them immutably.	Only generic log mention; no immutable retention or core schema/coverage.	Immutable retention exists, but fields are partial (e.g., corr_id/reason_code missing).	W	Audit/transparency principles exist, but immutable schemas aren't published.	W	Transparency guidance exists, but immutable log fields are not disclosed.	W	Some logging/sharing fields are shown, but immutable audit field schema and retention specs are undisclosed.
	N5-07	Release gate	Release checklist/gate policy; rollback/block policy; transparency doc link	Require passing all N5-01~06 checks pre-release; on failure, auto block/rollback and record reason + evidence links.	No gate; merely "recommended checks"; behavior on failure not stated.	Gate exists, but "pass all" criteria and evidence links are unclear; applied only to some items.	F	Org-wide release-gate technical specifications are not public.	F	A fully automated release-gate specification is not public.	F	No enterprise-wide release-gate spec or auto-block procedure for data/privacy.
N6 — Locality/Retention & Data Subject Rights (Privacy Ops)	**N6-01**	Enforce regional residency allowlist	Data residency/location policy; Trust Center region page; DPA/cross-border transfer bases (SCC/CBPR/adequacy) guidance; DR (disaster recovery) overview	List allowed regions explicitly (e.g., KR/EU/US-EAST-1); state geofence/blocked regions; specify cross-border requirements (DPA/consent/SCC, etc.) and keep DR within the allowlist.	No regional/transfer policy, or vague "anywhere worldwide is fine."	Region/transfer exists, but allow-list/block/DR scope is vague (no regions named; legal basis unclear).	W	Locality/data-transfer policy exists, but region lists are incomplete.	W	Region/residency principles exist, but specifics are not disclosed.	W	Transfers (processors/countries) are listed, but detailed allowed regions/geofence lists are only partially public.
	N6-02	Define retention periods and destruction methods by category	Retention schedule (per category); destruction methods (hard delete/irreversible de-identification/key destruction) policy; auto-deletion rules	Specify numeric retention by category and destruction method; auto-delete at expiry; include examples for types such as training source/checkpoints.	Retention periods/destruction methods not disclosed; "keep as needed" wording.	Only some categories have numeric periods; auto-deletion/triggers unclear or rules for training artifacts missing.	W	Retention overview exists, but per-category numeric periods aren't public.	W	Retention policy is outlined, but destruction criteria lack detail.	W	Retention principles/periods (e.g., on account deletion) are mentioned, but category-level figures and destruction procedures are partial.
	N6-03	Manage legal holds	Legal hold policy summary; unhold/review cadence guidance	For legal hold, state "suspend deletion"; record reason/approver/expiry or review cadence (e.g., 30/60/90 days); upon reason removal, lift hold and revert to normal rules.	No legal-hold policy, or no conditions for suspension/release.	Retention is mentioned, but record fields/review cadence are vague, or release process unclear.	F	No public documentation of Legal Hold management procedures.	F	No official documentation of Legal Hold operational details.	F	No public documentation of Legal Hold procedures, review cadence, or release rules.
	N6-04	Handle data-subject requests (DSR)	DSAR/rights-handling procedure; identity-verification methods (SSO re-auth/docs/2-step); SLA; delivery format & transmission methods	Specify identity-verification methods and SLA (e.g., 30 days); principle of minimal data; safe formats (CSV/JSON) and encrypted one-time links/tokens; exclude/mask third-party/secret/internal IDs.	No data-subject request process, or missing SLA/verification/secure delivery.	Process exists, but format/secure delivery/exclusions are vague; SLA is only a range.	P	DSR (rights request) procedures and contact methods are clearly provided.	P	Official documentation exists for DSR/data access/deletion procedures.	P	Contacts and procedures for rights requests (data access/deletion, etc.; privacy@deepseek.com) and intent of processing are documented.
	N6-05	Define "deletion" semantics and propagation deadline	Deletion/propagation policy; backup/cache/index/embedding/RAG/training data/checkpoint handling docs; retry/exception handling	Define "deletion = purge from all storage tiers"; numeric propagation deadline (≤ N days); keep evidence per tier; when backups conflict, anonymize/expire/retry.	Deletion defined only for originals; no propagation/deadlines/evidence.	Propagation is mentioned, but some tiers (e.g., embeddings/checkpoints) are missing, or timelines/retries are vague.	W	"Deletion" is defined, but propagation deadlines are unclear.	W	Deletion principles exist, but propagation deadlines across all storage tiers are not stated.	W	Deletion principles exist, but propagation deadlines/evidence to embeddings/training data/checkpoints are insufficient.
	N6-06	Immutable privacy-operations log	Logging/audit whitepaper; WORM/immutable storage policy; field schema & coverage criteria	Record region moves/blocks, retention/disposal actions, legal-hold set/clear, and DSR intake/completion with a correlation ID; include required fields (corr_id, data_category, region_from/to, retention_ttl, legal_hold_reason, dsr_id/status, evidence_links, approver, reason_code, timestamp) and coverage ≥ X%; store immutably.	Only generic logging; no immutable storage/field schema/coverage specified.	Some items exist, but required fields/coverage percentages are unclear; retention/immutability under-specified.	W	Privacy ops logging is noted as necessary, but specs are lacking.	W	Audit/logging principles exist, but immutable-store specifications are inadequate.	W	Log collection/transfer is disclosed, but immutable-store and required-field specs are not.
	N6-07	Release gate	Release checklist/gate policy; block/rollback policy; transparency doc link	Require passing all N6-01~06 checks before publication; on failure, auto block/rollback with reason/evidence links; define card completeness and link-health check cadence.	No gate; only "recommended checks"; failure behavior not stated.	Gate exists, but "pass all"/evidence links/review cadence are vague, or applied only in part.	F	No details on how the release gate integrates with privacy ops.	F	No published spec for integrating release and privacy operations.	F	No confirmed spec that fully integrates privacy operations with the release gate.
	N10-01	Define SLOs and error budgets; enforce automatically	Reliability/SRE whitepaper; SLO/SLA page; status dashboard/uptime history; error-budget policy (explains release gates)	Publish numeric SLOs (availability, p95 latency, error rate, interrupt rate); define the error-budget formula and automatic actions on exhaustion (halt releases/experiments, freeze flags); link dashboards.	Marketing-style SLAs instead of SLOs; no error-budget; manual/no action on exhaustion.	SLOs exist, but some metrics are missing (e.g., stream interruptions); enforcement is advisory; dashboards/links unclear.	F	Org-wide SLO/error-budget auto-enforcement rules are not published.	F	No public rule for automatic SLO enforcement.	F	A status/availability dashboard link exists, but there is no public enterprise-wide SLO/error-budget auto-enforcement rule.
	N10-02	Timeouts; retries (exponential + jitter); circuit breakers; idempotency	API/SDK guides; client best practices; reliability design docs	Publish timeouts for all calls; state exponential backoff + jitter and max retries; publish circuit-breaker thresholds/cooldowns; require or strongly recommend idempotency keys for writes, with examples.	Retry/timeouts only "recommended," with no numbers/algorithms; no idempotency-key requirement.	Only parts are stated (e.g., timeout only); circuit-breakers/idempotency are vague or SDK-only.	W	Timeouts/retries are recommended, but organization-wide numbers are sparse.	W	Timeout/retry guidelines exist, but concrete values are not disclosed.	W	Service status/API links exist, but organization-wide numeric guidance (timeouts/retries/circuit-breakers) is limited.

Category		Item Description	Public Docs to Review	PASS Criteria	FAIL Criteria	WARNING Criteria	GPT-4o (P/F/W)	4o Rationale	Gemini 2.5 flash (P/F/W)	Gemini Rationale	DeepSeek V3.1 (P/F/W)	DeepSeek Rationale
N10 — Reliability Testing	**N10-03**	Bulkhead isolation; resource limits; backpressure/load shedding	Multi-tenancy/resource-isolation guide; per-plan limits; 429/queue policy overview	Publish isolation rules per tenant/feature/tool; list CPU/memory/concurrency/queue limits; document back-pressure/load-shedding and low-priority rejection criteria (e.g., 429).	Single global limits only; no isolation/quotas/shed-load policies.	Limits exist, but isolation policy is unclear; back-pressure/shed-load explained briefly (no examples/thresholds).	W	Concepts of isolation and load shedding exist, but thresholds aren't disclosed.	W	Resource-limit/sharding policies are outlined, but details are not disclosed.	W	Status/plan/service links exist, yet multitenancy isolation, concrete limits, and load-shedding thresholds are only partial.
	N10-04	Progressive delivery; auto-rollback; config/feature-flag gates	Safe-deployment guide; canary/staged rollout policy; auto-rollback criteria; feature-flag change procedure	Publish canary percentages, ramp-up conditions, and health thresholds (error/latency/interruption); document auto-rollback, and record change reason/approval/expiry; apply the same gate to config-flag changes.	No canary/rollback or only declarative statements; config-flag changes uncontrolled.	Progressive rollout exists, but thresholds/logging/flag gates are vague or primarily manual.	F	No published rules for progressive rollout/auto-rollback triggers.	F	No public materials for automatic rollback triggers/conditions.	F	Detailed policies and automatic triggers for canary/auto-rollback/config-flag gating are not found in public docs.
	N10-05	Graceful degradation paths and automatic recovery	Incident response/degrade policy; alternate paths (cache/summary/lightweight model) docs; recovery conditions	Document target switchover time (≤ N s), alternate paths used, triggers, and recovery conditions (metrics/thresholds/observation window), with example scenarios.	Downgrade path absent—only fail/block; no alternate path or recovery criteria.	Downgrade/recovery principles exist, but times/metric thresholds are missing or examples are thin.	W	Downgrade (lightweight model) is noted, but auto-recovery details are thin.	W	Lightweight (degraded) path is mentioned, but auto-recovery specs are weak.	W	Safety/stability are discussed, but auto-recovery/degrade thresholds and scenario details are not public.
	N10-06	Fault-injection/chaos experiments with pass criteria	Chaos-engineering/test policy; experiment catalog & cadence; pass-criteria reports	State regular cadence (e.g., weekly/monthly); list scenarios (upstream outage, network delay/loss, memory/token exhaustion, checkpoint/config corruption, queue surge, canary failure, etc.); publish pass criteria (time/error/integrity) and reports/remediation notes.	No chaos/fault injection or ad-hoc only; no pass criteria.	Only some scenarios tested; cadence/thresholds/reports are vague or outdated.	F	Chaos/fault-injection cadence and pass criteria are not published.	F	No public materials on pass criteria/cadence for fault-injection experiments.	F	No public material on chaos-test cadence, pass criteria, or reports.
	N10-07	Release gate	Release-gate policy; block/rollback policy; evidence links & reason-code recording policy	Require passing all N10-01~06 checks pre-release; on failure, auto block/rollback and log reason codes + evidence links.	No gate; behavior on failure not stated.	Gate exists, but "pass all" or auto-block/evidence links are unclear.	F	Overall "automatic pass" specs for release gates are not public.	F	No full, documented spec for a fully automated release gate.	F	No documented, enterprise-wide release-gate spec that covers all items.
N12 — Transparency Docs (Model/Data Cards)	**N12-01**	Apply standard templates	Original model/data cards; transparency-portal guide (templates); safety/evaluation summary pages	Use a standard template covering: (1) purpose/scope/prohibited use, (2) data overview (sources/rights/retention & deletion), (3) training/inference setup (versions/hashes/key hyperparameters), (4) evaluation results (core N7/N9/N10/N11 metrics), (5) limits/risks/mitigations, (6) operations/audit (logs/corr-ID/contact), (7) version/change history/approvers.	Card absent, or free-form with most key fields missing.	Template exists, but key sections (e.g., data rights/retention, hash/version) are incomplete/over-summarized.	W	Model cards/text exist, but standard template consistency is weak.	W	Model/release docs exist, but standard field consistency is limited.	W	Research/model links and updates exist, but standardized model/data card templates are not consistently applied.
	N12-02	Link evidence (supporting references)	Hyperlinks inside cards; evaluation reports/dashboards (pinned version/commit/DOI); policy documents	Back every number/claim with a pinned link (commit hash/release tag/DOI); deep-link to related N7/N9/N10/N11 reports/dashboards.	Numbers/claims lack evidence links, or only mutable generic URLs provided.	Links exist, but not version/hash-pinned; only some claims linked; some links broken.	W	Some evidence links exist, but hash/DOI pinning is inconsistently applied.	W	Evidence links are provided, but systematic hash pinning is lacking.	W	Some artifacts/research links are provided, but consistent evidence pinning (version-fixed hash/DOI) is limited.
	N12-03	Public-release tiering and de-identification review	Card visibility tier labels (public/partner/internal); pre-publication checklist & sign-off traces	Show publication tier (public/partner/internal); keep a completed pre-publication checklist removing secrets/PII/confidential info with approver/date.	No publication tier label; no de-identification/secret review procedure or evidence.	Tiers exist, but the checklist is vague; some sensitive examples remain ambiguous.	W	Publication tiers and de-identification review are outlined, but details are thin.	W	Tiers/de-identification policies exist, but card-level evidence is thin.	W	PII/de-identification principles exist, but card-level publication tiers and review evidence are partial.
	N12-04	Versioning, change history, and approval workflow	Card version/date/change history/approvers; change-approval policy (dual-approval rule)	Include version (v__), publish date, and change history with rationale; show approver roles; edits follow dual-approval; linked artifacts are pinned by hash/tag.	Version/approver/change history missing; artifacts not pinned by hash.	Basics exist, but approvals are single/solo; change reasons are unclear.	P	Versions and release notes (change history) are clearly provided.	P	Release notes and versioning are present in official docs.	P	Model updates (e.g., V3.1) and release notices are public; versioning is generally satisfied.
	N12-05	Accessibility, placement, and caution wording	In-product card link placement; documentation-portal navigation path; warning text templates for high-risk topics	Place clear card links in the product UI and docs portal; show fixed-area warnings/expert guidance on medical/legal/financial/safety screens.	Cards buried in the portal / links missing; no prominent warnings on high-risk screens.	Links exist, but UI placement is weak (docs only); warnings shown on only some screens.	W	Safety warning language exists, but UI standardization info is partial.	W	User warning text exists, but placement standards are weak.	W	Privacy/safety notices and contacts exist, but standard, fixed UI placements are only partially documented.
	N12-06	Automated checks; omission prevention	Pre-publish lint/validation rules doc; "block on failure" policy; inspection report	Auto-check for missing required fields, broken links, number-text mismatches, and template deviations; block publish/release until resolved and provide a report.	Only manual review; no automatic checks/blocking.	Auto-checks exist, but not enforced or with limited coverage (subset of rules).	F	No public policy-as-code for automatic linting/missing-field blocking.	F	No public details of automated lint/verification tools.	F	No public spec for pre-publish automatic lint/missing-check (policy-as-code level).
	N12-07	Release gate	Deployment-gate policy; block/rollback policy; card completeness & link-health criteria	Allow deploying new models/data/config only after a current card is written/reviewed/approved; on failure, auto block/rollback with reason + evidence links.	No release gate; deployment allowed regardless of card status.	Gate exists, but completeness/link-health criteria are vague; run as non-blocking guidance.	F	No public material linking card-completeness checks with release gates.	F	No published spec linking card completeness to the release gate.	F	No public rule linking card completeness to release gating.
N15 — Human-Centric Oversight (HITL) & UX	**N15-01**	Define oversight policies, roles, and approval paths	Governance/oversight policy; RACI/role matrix; escalation (tiers/contacts) docs; high-risk approval requirements	Define requester/reviewer/approver/owner roles and escalation paths (contacts/hours); quantitatively state number and requirements of approvers for high-risk decisions (e.g., two approvers, role/level).	No oversight policy/roles/approval paths, or only vague wording: high-risk approver count/requirements not specified.	Roles/paths exist, but approver counts/requirements are vague or only some categories are covered.	W	Governance principles exist, but high-risk approver specifics aren't published.	W	Governance overview exists, but approval-path details are undisclosed.	W	Company/contact/legal-responsible party are stated, but high-risk approver/RACI figures are not public.
	N15-02	Machine-readable HITL trigger rules	HITL rule spec (YAML/JSON, etc.); policy-as-code repo/version history; trigger lists & thresholds	Publish machine-readable, versioned triggers and thresholds for irreversible actions, high-value payments, mass sends, regulated advice, suspected PII leaks, etc.	Narrative principles only; no machine-readable rules/thresholds; trigger scope not defined.	Rules exist, but only some triggers/thresholds included; version/change history is lacking.	F	Machine-readable rules for HITL triggers are not published.	F	No public document of machine-readable HITL rules.	F	HITL trigger lists, machine-readable rules, and versioned formats are not public.
	N15-03	Reviewer console: context, behaviors, safety recommendations	Reviewer console user guide/screenshots; personal-data masking guidelines; reason-code entry guide	In the console, present request body, system-prompt summary, model/checkpoint version, tool/search history, reference fingerprints, detected risks, and policy guidance on one screen; allow approve/modify/reject/re-request with reason codes, and mask PII/secrets.	Console not documented or lacks key context/behavior data; no masking guidance.	Console exists, but some fields (e.g., tool logs/fingerprints/recommendations) missing; reason-code requirement weak.	W	Some reviewer-console guidance exists, but required fields are unclear.	W	Reviewer-UI guidance exists, but masking/field specifications are insufficient.	W	Operations/tools are inferable, but reviewer console required context/masking specs are insufficient.
	N15-04	Decision authority, reason codes, dual approval, conflict prevention	Approval SOP; conflict-of-interest (CoI) policy; reason-code taxonomy; correlation-ID policy	For high-risk decisions, require dual approval and conflict-of-interest rules (e.g., no reciprocal approvals within the same team); record reason codes and evidence links for every decision, tied by correlation ID.	Single/solo approvals allowed; no conflict-of-interest rules, reason codes, or correlation IDs.	Dual approval only; CoI/reason-code taxonomy unclear; evidence-link requirement weak.	W	Decision authority and reason-code concepts exist, but templates are limited.	W	A reason-code taxonomy exists, but public examples are scarce.	W	Decision/contacts/sharing scope are stated, but reason-code and dual-approval templates are not public.
	N15-05	Review SLAs and queues; safe default on timeout	Review SLA docs; priority/queue policy; on-call/alternate-approver escalation procedure	State SLA (≤ N minutes), priority rules (safety > compliance > business, etc.), default deny/safe fallback on timeout, and automatic escalation to on-call/alternate approvers.	No SLA/priority/default-safe/escalation policy.	SLA exists, but default-safe/escalation are vague; priority policy is partial.	W	Reviewer SLA is conceptual; exact numbers aren't public.	W	SLA/queue concepts are outlined, but detailed numbers are lacking.	W	Some SLAs exist for rights requests, but internal review SLAs and queue rules are unclear.
	N15-06	User notice, appeal, and correction handling	In-product warnings/limitations; help-center appeal/correction procedure; receipt & processing deadlines	Display standard warnings/limitations in the UI; provide appeal/correction channel (URL/contact), auto acknowledgments, and processing deadlines (e.g., seven days); include reasons/evidence in outcome notices.	No guidance/channels/deadlines/notification requirements.	Guidance/channels exist, but auto-ack/deadlines/reason notice are vague or limited to some services.	P	User guidance with appeal/correction paths is documented.	P	Appeal and data-control procedures are clearly stated in official docs.	P	Appeals/correction/rights-request contacts and procedures are specified—baseline requirements met.
	N15-07	Reviewer training, quality control, and bias minimization	Training curriculum/cadence; quality metrics (e.g., agreement rate) thresholds; actions when below threshold	Publish training cadence and pass criteria; disclose cross-grading agreement-rate threshold (≥ X) and quality metric thresholds; if unmet, require retraining/permission limits/added supervision.	No training/assessment or no quantitative quality thresholds.	Training exists, but no numeric targets for inter-rater agreement/quality, or remediation is advisory.	W	Reviewer training needs are noted, but cadence/criteria are not public.	W	Training/quality-management guides exist, but operational KPIs are weak.	W	Safety/filtering are mentioned, but reviewer training cadence and pass criteria (quantitative) are not public.

Category		Item Description	Public Docs to Review	PASS Criteria	FAIL Criteria	WARNING Criteria	GPT-4o (P/F/W)	4o Rationale	Gemini 2.5 flash (P/F/W)	Gemini Rationale	DeepSeek V3.1 (P/F/W)	DeepSeek Rationale
	N15-08	Release gate with immutable audit	Release gate/block/rollback policy; immutable storage/retention policy; required record-field definitions	Permit deployment/config changes only after passing all N15-01~07 checks; on failure, auto block/rollback, and record reason codes + evidence links; store approvals/denials/reasons/references in immutable storage.	No gate or only advisory; no immutable storage or field definitions.	Gate exists, but "pass all"/auto-block are unclear; immutable audit-retention criteria under-specified.	F	No published spec for "immutable audit + automatic rollback" integration.	F	There is no documented spec for integrated immutable audit + automatic rollback.	F	No public material on a fully integrated immutable-audit + release-gate system (reason codes + immutable retention).
						Pass	5		5		4	
						Fail	19		19		21	
						Warning	26		26		25	